FORENSIC INCIDENT WRITE-UP

Supply Chain Intrusion & Data Exfiltration Analysis — Grimvault Project

Incident Date: October 18, 2026	**Target Component:** gallows-stream / npm ecosystem
Severity Level: CRITICAL (Data Exfiltration & Token Theft)	**Analysis Method:** Pure Static Decoding & Traffic Reconstruction

1. Executive Summary

An investigation into a high-severity supply chain intrusion targeting the release pipeline of project gallows-stream was conducted following an npm registry maintainer account compromise. One week prior to a major Halloween special premiere, an encode engineer executed a routine npm install. The operation pulled a trojanized dependency (hushkit-crypto@1.3.0 via veil-assets@2.4.2).

The malicious package executed an obfuscated postinstall script, staged a secondary PowerShell loader (gh.ps1), gathered high-value repository secrets, and exfiltrated them via covert DNS tunneling. All exfiltrated DNS traffic was reassembled, validated against attacker-provided CRC32/HMAC checksums, and decrypted to recover the stolen secrets—including the primary release token.

2. Incident Timeline (UTC — 2026-10-18)

Time (UTC)	Source / Artifact	Event Description
13:45:03	Sysmon, npm log	cthorn runs npm install in gallows-stream. veil-assets@2.4.2 pulls trojanized dependency hushkit-crypto@1.3.0.
13:45:41	Sysmon	hushkit-crypto postinstall hook executes node install-hook.js.
13:45:43	Sysmon, PCAP	Hook resolves veilshroud.fonts.net (198.51.100.201) and GETs fake font /wp-content/fonts/inter-var.woff2.
13:45:44	Sysmon	Stage 2 loader written to disk at C:\ProgramData\gh\gh.ps1.
13:45:44–49	Sysmon, node_modules	Hook deletes install-hook.js and swaps clean package.md over

		package.json to scrub execution traces.
13:45:47	Sysmon	Hidden PowerShell process executes gh.ps1 (-NoP -NonI -w hidden -ep bypass).
13:45:52	PCAP	HTTP POST exfiltration attempt via proxy (10.20.0.8:3128) blocked (403 Forbidden - Newly Observed Domain).
13:46:11	PCAP	Fallback to DNS C2. TXT lookup for grimveil.net returns NXDOMAIN; lookup for hollowmoth.com succeeds.
13:46:15–47:08	PCAP	73 data chunks exfiltrated across DNS queries using custom Base32 encoding.
13:48:47	PCAP	Final fin beacon transmitted by malware.

3. Technical Analysis & Intrusion Chain

Stage 1: Supply Chain Dependency Hijack

The target project gallows-stream specified veil-assets@2.4.2 in its dependencies. An upstream compromise of a maintainer's account allowed attackers to inject hushkit-crypto@1.3.0 as an unlisted transitive dependency. Inspection of the installed node_modules showed a clean codebase; however, auditing the raw tarball (f4_...) within the npm cache revealed an obfuscated install-hook.js bound to a postinstall lifecycle script.

- **Self-Cleaning Routine:** Anti-Forensic Wipe: Immediately post-execution (13:45:44–13:45:49 UTC), install-hook.js erased itself and renamed package.md to package.json, restoring a pristine appearance.

Stage 2: Payload Retrieval & Key Derivation

Upon execution, install-hook.js initiated outbound DNS resolution for veilshroud.fonts.net (198.51.100.201) and fetched a binary payload masquerading as a Web Open Font Format file (/wp-content/fonts/inter-var.woff2). String table analysis revealed the cryptographic key derivation:

> **Derivation Formula:** Key = SHA256(nonce || seed)

The nonce was extracted dynamically from the X-Font-Range HTTP response header. Decryption of the payload yielded the secondary stage written to disk at C:\ProgramData\gh\gh.ps1.

Stage 3: Reconnaissance & DNS Exfiltration Channel

Static decompression of gh.ps1 revealed an obfuscated Base64/Gzip PowerShell stealer designed to extract host metadata and application secrets. The stealer computed its victim identifier via MD5(MachineGuid)[:8], resulting in 0de039b0—matching the cfg-0de039b0 lookup recorded in Sysmon logs.

When direct HTTP POST exfiltration to proxy 10.20.0.8:3128 was rejected (403 Forbidden), the payload seamlessly fell back to covert DNS tunneling:

- **1. Handshake:** Issued a TXT query to hollowmoth.com to obtain session keys (after grimveil.net returned NXDOMAIN).
- **2. Encryption:** Compressed and encrypted gallows-stream/.env and related credentials using AES-256-CBC.
- **3. Tunneling:** Encoded ciphertext into Base32 subdomains and emitted 73 DNS queries over a 53-second window.

4. Data Recovery & Flag Decryption

To recover the exfiltrated assets, raw DNS queries and responses were extracted from the network capture packet by packet:

- **Reassembly:** Reconstructed 73 distinct data chunks, resolving 6 duplicate queries/retries without missing chunks.
- **Decoding:** Stripped host prefixes/index tags and decoded the custom Base32 stream.
- **Verification:** Reassembled payload CRC matched the attacker's expected 0af1bfd2, and the first 16 bytes matched the derived HMAC.
- **Result:** Decryption of the stolen gallows-stream/.env file yielded the official incident flag.

> **Stolen Flag / Token:** `GRIMVAULT_RELEASE_TOKEN=forensic{231e4dd176071ce350260680}`

5. Compromised Secrets & Scope of Impact

Forensic decryption of the exfiltrated archive confirmed that multiple critical credentials were leaked alongside the release token. The following high-value secrets must be rotated immediately across all production systems:

Secret / Credential	Description / Impact Scope
GRIMVAULT Release Token	Primary production deployment key
npm Authentication Token	Registry publishing & write access
GitHub Personal Access Token	Harvested from .git-credentials
PostgreSQL Connection URI	Production database host & login credentials
Media Encoder API Key	Transcoding service access key
Render-Console API Key	Infrastructure management access token
Webhook Secret	Ingress payload signature verification key
Session Secret / Restic Password	Session encryption key reused as Restic backup repo password
SSH Private Keys & known_hosts	Host access keys for staging/production servers

6. Indicators of Compromise (IoCs)

Network Indicators

Indicator	Type	Context / Description
`198.51.100.201`	IPv4 Address	Stage 2 HTTP C2 server (veilshroud.fonts.net)
`198.51.100.53`	IPv4 Address	Authoritative DNS exfiltration name server
`veilshroud.fonts.net`	FQDN	Stage 2 binary download host
`x.grimveil.net`	FQDN	Primary DNS exfiltration domain (returned NXDOMAIN)
`x.hollowmoth.com`	FQDN	Active DNS exfiltration domain
`x.tallowwick.io`	FQDN	Fallback DNS exfiltration domain

Host & Artifact Indicators

Indicator	Type	Context / Description
`hushkit-crypto@1.3.0`	npm Package	Malicious trojanized dependency

`veil-assets@2.4.2`	npm Package	Parent package bringing in trojan dependency
`C:\ProgramData\gh\gh.ps1`	File Path	Stage 2 PowerShell loader
`install-hook.js`	File Path	Postinstall execution script (transient file)

7. Strategic Remediation Checklist

- **Credential Revocation:** Immediately revoke and regenerate all compromised credentials (npm token, GitHub PAT, Postgres URI, API keys, SSH keys, Restic repo password).
- **Dependency Purge:** Purge hushkit-crypto and veil-assets from local npm caches, lockfiles, and enterprise artifact registries. Audit lockfiles across all organization repos.
- **Endpoint Quarantine & Sweep:** Isolate developer workstations where gh.ps1 executed. Scan C:\ProgramData\gh\ for remaining persistence artifacts.
- **Network Blocklist:** Block outbound access to IPs 198.51.100.201 and 198.51.100.53, as well as domain wildcard patterns *.fonts.net, *.grimveil.net, *.hollowmoth.com, and *.tallowwick.io.
- **Pipeline Hardening:** Enforce strict dependency pin rules, enable npm audit / automated SAST scanning in CI/CD, and block execution of postinstall scripts (npm install --ignore-scripts) on build servers.